

CHACADOM INVESTMENTS

Safeguards & Risk-Management Plan

Operational detail of how consumer interests, client money, data and platform integrity are protected during the test: a three-lines governance model, a twelve-risk register with named owners, KYC/AML controls, Data Protection Act compliance, incident-response classes with CMA notification times, and a rehearsed wind-down that ranks investors' capital ahead of the applicant's recovery.

PRODUCT UNDER TEST

Keja.ai Tokenization Pilot

APPLICANT CONTACT

Westlands, Nairobi · info@chacadom.com · +254 108 611 387

ISSUED

September 2026
CMA-SR-2026-01 V1.0

SANDBOX.CMA.OR.KE

Table of Contents

1. Executive Summary	1
2. Purpose, Scope and Regulatory Context	1
3. Risk Governance Framework	2
4. Risk Register	2
5. Consumer Protection Safeguards	4
5.1 Eligibility, suitability and caps	4
5.2 Disclosure and fair marketing	4
5.3 Money-handling and the investor journey	4
6. KYC, AML and Financial-Crime Controls	5
7. Data Protection and Privacy	5
8. Technology and Cybersecurity Controls	5
9. Business Continuity and Wind-Down Planning	6
10. Monitoring, Audit and Regulatory Reporting	6
11. Document Control and Review Cadence	7

1. Executive Summary

This Safeguards and Risk-Management Plan accompanies Chacadom Investments' application to the Capital Markets Authority (CMA) Regulatory Sandbox for the Keja.ai Tokenization Pilot. Its purpose is to show, in operational detail, how consumer interests, client money, data and the integrity of the platform are protected while the testing described in the accompanying Testing Plan is under way. The plan is written to be auditable: every control named here has an owner, a frequency and an evidence trail, and the risk register in Section 4 is reviewed monthly and re-issued to the CMA with each phase report.

The plan is built on three principles. First, failure must be contained: hard participation and exposure caps, segregated client money and a rehearsed wind-down mean the maximum credible loss is small and bounded. Second, protection must be structural rather than Promissory: controls are enforced by system logic and dual authorisation, not by policy statements alone. Third, honesty is a control: every projection is labelled with its assumptions, every complaint is logged with its outcome, and every incident is reported — because in a sandbox, concealment converts a manageable incident into a disqualifying one.

Regulatory process — as published by the CMA

Application and documents are submitted to the Capital Markets Authority through the Regulatory Sandbox portal (sandbox.cma.or.ke). The CMA reviews a complete application within 14 working days; if approved, the applicant receives a letter to participate and may test live for up to 12 months. Exit from the sandbox is by one of three routes: a full licence, a letter of no objection, or rejection.

2. Purpose, Scope and Regulatory Context

The plan governs the conduct of Chacadom Investments and its staff throughout the sandbox test of the Keja.ai Tokenization Pilot: from the first public disclosure of the product, through onboarding, subscription, income distribution and statements, to complaints, incidents and wind-down. It binds the applicant's directors and employees and, by contract, every vendor that touches client money, personal data or the ledger. It does not replace the Testing Plan; where the two documents overlap, the stricter control applies. The plan will be maintained throughout the test and for so long afterwards as obligations to pilot investors remain.

Regulatory context is fixed by the CMA's published sandbox process: submission through the sandbox portal, review within 14 working days, a participation letter if approved, live testing for up to 12 months, and exit by full licence, letter of no objection or rejection. The applicant treats the participation letter's conditions as minimum standards incorporated into this plan, and any CMA direction as overriding anything to the contrary stated here.

3. Risk Governance Framework

Risk management follows a three-lines model scaled to the size of the pilot. The first line is the operating team, which owns risks in the processes it runs and cannot execute controlled actions without the platform's enforced checks. The second line is the compliance officer — an independent role with direct board access and a standing right to communicate with the CMA — who owns this plan, the risk register, monitoring and training. The third line is the board, which receives a monthly risk report, approves phase gates and cap changes, and commissions the external reviews below. No individual can simultaneously onboard an investor, receive their money and reconcile the account: segregation of duties is enforced in role permissions and audited quarterly.

- Board — approves this plan, phase gates, and the wind-down runbook; receives monthly risk and incident reports.
- Compliance officer — independent; owns the register, monitoring, complaints oversight, CMA liaison and training records.
- Chief Operating Officer — owns operating procedures, vendor contracts and platform controls.
- External support — a professional firm performs the annual-style client-money and ledger audit; a valuer independent of the sales desk values each underlying asset.

Escalation is time-bound. Any staff member may raise a concern to the compliance officer without intermediate approval; suspected client-money or ledger incidents reach the compliance officer and COO within 4 hours of detection, the board within 24 hours, and the CMA within the notification times in Section 8.3 of the Testing Plan.

4. Risk Register

The register below lists the material risks identified for the pilot, their assessed likelihood and impact on the consumer-protection scale, and the mitigations in force. Likelihood and impact are assessed on a three-point scale after mitigation; any risk assessed Medium/Medium or worse is on the compliance officer's monthly watchlist, and any that degrades between reports triggers an interim CMA notification. The register is a living document: new risks are added as identified and closed risks are retained with their history.

Risk	Category	L	I	Key mitigations
Mis-selling: investors misunderstand risk or projected yields	Consumer	M	H	Suitability quiz before subscription; projections always labelled with assumptions; marketing pre-approval by compliance; 7-day cooling-off with refund

Risk	Category	L	I	Key mitigations
Loss of client money through misuse or error	Client money	L	H	Segregated account at a regulated bank; dual authorisation for releases; staged drawdown against milestones; monthly third-party reconciliation
Fraudulent subscription (identity theft, stolen funds)	Financial crime	M	M	KYC with document and liveness checks; sanctions screening; AML transaction monitoring; suspicious-activity escalation to the FRC
Money laundering through the subscription flow	Financial crime	L	H	Source-of-funds evidence above threshold; enhanced due diligence; internal AML policy aligned to the POCAMLA obligations
Ledger record diverges from the definitive register	Technology	L	H	Permissioned ledger with immutable append; daily reconciliation to the definitive register; divergence halts subscriptions and triggers CMA notice
Platform outage blocks subscriptions, statements or withdrawals	Technology	M	M	Recovery-point and recovery-time objectives (Section 8); read-only fallback statements; incident comms templates
Personal-data breach (investors' KYC and financial data)	Data	M	H	Data minimisation; encryption in transit and at rest; role-based access; ODPC notification path; annual penetration test
Underlying asset underperforms projections	Market	M	M	Conservative underwriting; independent valuation; assumptions displayed with projections; no guaranteed-return language anywhere
Buy-back facility cannot meet demand at stress	Liquidity	L	M	Buy-back reserve funded from fees; Phase 3 stress test; wind-down waterfall prioritises investor returns
Key-person dependency in a small team	Operational	M	M	Documented procedures; shadowing for critical roles; board succession cover; vendor SLAs with named alternates
Vendor failure (payments, ledger hosting, KYC provider)	Operational	L	M	Contractual SLAs and audit rights; escrow of critical configuration; tested exit plan per vendor; no sole-source dependency for client money
Regulatory non-compliance discovered mid-test	Regulatory	L	H	Compliance officer's independent line to the CMA; self-report policy; remediation with documented cause and recurrence test

Table 1 — Risk register (L = likelihood, I = impact, assessed after mitigation).

5. Consumer Protection Safeguards

5.1 Eligibility, suitability and caps

Before any subscription is accepted the platform verifies identity, screens sanctions, and administers a short suitability assessment covering income bracket, investment objective, loss-capacity and comprehension of the risk factors. Investors who fail any element are declined with a plain reason. The hard caps in Section 5.3 of the Testing Plan are enforced by the platform — a subscription above the cap cannot be submitted, not merely discouraged — and the cap table is re-stated in every investor's statement so the limit is visible at the point of each decision.

5.2 Disclosure and fair marketing

Every offering carries a digital investment memorandum stating the asset, fraction price, projected net yield with its assumptions, all fees, the holding structure, conflicts, and exit mechanics in plain language. Compliance pre-approves all marketing; yield figures may never appear without the adjacent assumption panel; and words such as "guaranteed", "risk-free" or "capital-protected" are prohibited. The platform carries a persistent sandbox banner and a statement that pilot investments are not covered by any compensation scheme.

5.3 Money-handling and the investor journey

- Client money is received only into a segregated account with a regulated bank; operating funds never commingle.
- Releases require dual authorisation and occur only against verified completion milestones of the offering.
- A 7-day cooling-off period follows each subscription, with a full refund and no quibble.
- Income is distributed quarterly and every statement shows the distribution alongside its computation.
- Complaints are acknowledged within 24 hours, resolved or escalated within the published SLA, and reported in the monthly CMA return.

The complaints process accepts submissions through WhatsApp, email and the platform; every complaint receives a reference, an owner and a written outcome; and upheld complaints are analysed for root cause. The compliance officer publishes complaint themes to the board monthly and includes them in phase reports, because complaint patterns are the earliest honest signal of consumer harm.

6. KYC, AML and Financial-Crime Controls

The pilot operates a risk-based KYC programme aligned to Kenyan obligations under the Proceeds of Crime and Anti-Money Laundering framework: identity verification with document and liveness checks for every investor, source-of-funds evidence for subscriptions above the platform's internal threshold, enhanced due diligence for higher-risk cases, and sanctions and PEP screening at onboarding and on each subsequent subscription. Transaction monitoring reviews subscription and distribution patterns for structure that suggests layering; anything suspicious is escalated through the appointed money-laundering reporting path without tipping off the customer. Records are retained for the statutory period and made available to competent authorities on request. Staff receive AML training before Phase 1 and annually thereafter, with attendance recorded.

7. Data Protection and Privacy

The pilot collects only the personal data necessary for the purposes above: identity and KYC evidence, suitability responses, subscription and distribution records, and contact details. The legal basis, retention periods and recipients for each category are recorded in a data map maintained by the compliance officer. Data is encrypted in transit and at rest; access is role-based and logged; production data is never used in test environments. The applicant will register with the Office of the Data Protection Commissioner as required and operate the breach-notification path: any personal-data breach is contained immediately, assessed within 24 hours, and notified to the ODPC and affected investors within statutory timeframes. Investors' rights — access, correction and objection — are serviced through a documented request procedure with response tracking.

8. Technology and Cybersecurity Controls

The platform applies the controls a client-money system requires: least-privilege access with multi-factor authentication for administrative actions; immutable audit logs of every state change affecting interests or funds; daily reconciliation of the permissioned ledger against the definitive register with automatic halt on divergence; encrypted backups with a recovery-point objective of 24 hours and a recovery-time objective of 4 hours for investor-facing functions; dependency pinning and a secure development process with review gates; and an annual third-party penetration test whose findings are tracked to closure and summarised to the CMA. Vendor hosting and payment services are contracted with audit rights, data-processing terms and Kenya-jurisdiction commitments.

Incident class	Detection	Response	CMA notification
Client-money anomaly	Daily reconciliation; bank alert	Freeze releases; investigate; dual-authorised correction	Within 24 hours
Ledger divergence	Automated daily check	Halt subscriptions; reconcile; forensic cause analysis	Within 24 hours
Personal-data breach	Access-log anomaly; user report	Contain; assess scope; ODPC and investor notice as required	Within 24 hours of confirmation
Platform outage beyond RTO	Monitoring	Invoke read-only fallback; vendor escalation; investor comms	In the monthly return, or sooner if funds affected
Cap breach	Platform logic (prevents, not detects)	Suspend subscriptions; root-cause; report	Within 2 business days

Table 2 — Incident classes, response and regulatory notification.

9. Business Continuity and Wind-Down Planning

Business continuity covers the plausible failure modes of a small operating team: documented procedures and shadow roles for all critical functions; vendor SLAs with named alternates; escrowed configuration and source so that the ledger and records survive a vendor failure; and a communications tree that reaches every investor through at least two independent channels. The wind-down runbook — rehearsed in Phase 3 together with the buy-back stress test — specifies, on a named-role basis: the halt of new subscriptions; the communication to investors with plain-language reasons; the return-of-funds waterfall (client balances first, then realised proceeds by holding, with fees waived to the extent permitted); the archival of the ledger and registers in a verifiable read-only form; and the final report to the CMA. In every exit scenario the applicant's recovery ranks behind the investors' capital.

10. Monitoring, Audit and Regulatory Reporting

Monitoring runs on three cadences. Daily, automated: reconciliations of client money and ledger state, cap checks and access-log review. Monthly, human: the compliance officer reviews the risk register, complaint themes, vendor SLA performance and training records, and issues the board and CMA operating return. Per phase: an external professional firm audits client-money handling and ledger integrity, and the compliance officer re-issues the risk register with movements explained. Findings are tracked to closure with named owners and dates; overdue findings escalate to the board automatically. The CMA may inspect any record at any time, and this plan is submitted with the standing commitment that raw extracts — ledger, bank reconciliations, complaint files — are available on request without prior

notice.

11. Document Control and Review Cadence

This plan is version-controlled and reviewed monthly by the compliance officer, with a full re-issue at each phase gate of the Testing Plan. Material amendments take effect only after CMA notification, and the version history is included with every phase report so that the Authority can see not only what changed but when and why. The plan, together with the Testing Plan, the certified incorporation documents, the certified list of directors and shareholders, the CVs of founders and key management and the application fee of KES 10,000, completes the documentary submission for the Chacadom Investments sandbox application.

Document control

Prepared by Chacadom Investments · Westlands, Nairobi · info@chacadom.com · +254 108 611 387 ·
September 2026 · Document ref CMA-SR-2026-01 v1.0